CMMC Implementation Guide

Cybersecurity Maturity Model Certification for Defense Industrial Base

Published by NexDyne Technology
Intelligence, Delivered

Executive Summary

The Cybersecurity Maturity Model Certification (CMMC) is a unified standard for implementing cybersecurity across the Defense Industrial Base (DIB). Required for all Department of Defense (DoD) contractors and subcontractors, CMMC combines various cybersecurity standards and best practices into a single framework with multiple maturity levels.

This comprehensive guide provides defense contractors with a structured approach to achieving and maintaining CMMC certification, protecting Controlled Unclassified Information (CUI), and securing DoD contracts.

Why CMMC Matters:

- **Mandatory Requirement:** CMMC certification required for all new DoD contracts by 2025
- **Market Access:** $600+ billion annual DoD contract opportunities
- **Supply Chain Impact:** Prime contractors require subcontractor certification
- **Competitive Advantage:** Early certification differentiates your organization
- **Enhanced Security:** Protects sensitive defense information and intellectual property

Understanding CMMC Levels

CMMC 2.0 streamlines the previous five-level model into three levels aligned with NIST SP 800-171 and other standards:

Level 1: Foundational

- **Requirements:** 17 basic cybersecurity practices
- **Assessment:** Annual self-assessment
- **Scope:** Protects Federal Contract Information (FCI)
- **Typical Organizations:** Contractors handling only FCI, no CUI
- **Implementation Time:** 2-4 months
- **Estimated Cost:** $25,000-$75,000

Key Controls:

- Basic access control and identification
- Media protection
- Physical protection
- System and communications protection
- System and information integrity

Level 2: Advanced

- **Requirements:** 110 security practices (NIST SP 800-171)
- **Assessment:** Triennial third-party assessment for critical programs; self-assessment for others
- **Scope:** Protects Controlled Unclassified Information (CUI)
- **Typical Organizations:** Most DoD contractors handling CUI
- **Implementation Time:** 6-12 months
- **Estimated Cost:** $150,000-$500,000

Key Control Families:

- Access Control (AC) - 22 controls
- Awareness and Training (AT) - 3 controls
- Audit and Accountability (AU) - 9 controls
- Configuration Management (CM) - 9 controls
- Identification and Authentication (IA) - 11 controls
- Incident Response (IR) - 6 controls
- Maintenance (MA) - 6 controls
- Media Protection (MP) - 9 controls
- Personnel Security (PS) - 2 controls
- Physical Protection (PE) - 8 controls
- Risk Assessment (RA) - 3 controls
- Security Assessment (CA) - 7 controls
- System and Communications Protection (SC) - 12 controls
- System and Information Integrity (SI) - 5 controls

Level 3: Expert

- **Requirements:** 110+ enhanced security practices (subset of NIST SP 800-172)
- **Assessment:** Government-led assessment
- **Scope:** Protects high-value CUI and critical national security information
- **Typical Organizations:** Prime contractors on critical defense programs
- **Implementation Time:** 12-24 months
- **Estimated Cost:** $500,000-2$ million+

Additional Requirements:

- Advanced persistent threat protection
- Enhanced detection and response capabilities
- Supply chain risk management
- Asset management and tracking
- Multi-factor authentication for all access

Phase 1: Scoping and Planning (Months 1-2)

☐ Determine Target CMMC Level

- [ ] Review current and planned DoD contracts
- [ ] Identify CUI handling requirements
- [ ] Assess critical program designations
- [ ] Determine required CMMC level (1, 2, or 3)
- [ ] Verify subcontractor CMMC requirements

☐ Define CUI Environment

- [ ] Identify all systems that process, store, or transmit CUI
- [ ] Map data flows for CUI throughout organization
- [ ] Document CUI lifecycle from receipt to destruction
- [ ] Identify CUI storage locations (physical and digital)
- [ ] Establish clear CUI boundaries

☐ Conduct Gap Assessment

- [ ] Evaluate current security posture against CMMC requirements
- [ ] Document existing security controls and practices
- [ ] Identify control gaps and deficiencies
- [ ] Assess technical infrastructure readiness
- [ ] Evaluate policy and procedure maturity
- [ ] Calculate System Security Plan (SSP) score

☐ Build CMMC Team

- [ ] Assign CMMC Program Manager
- [ ] Designate System Security Officer
- [ ] Identify control implementation owners

- [ ] Engage Registered Practitioner (RP) or Registered Provider Organization (RPO)
- [ ] Establish executive sponsorship
- [ ] Define roles and responsibilities

☐ Develop Implementation Roadmap

- [ ] Create detailed project plan with milestones
- [ ] Allocate budget for implementation and assessment
- [ ] Establish timeline to certification
- [ ] Identify quick wins and priority areas
- [ ] Define success metrics and KPIs
- [ ] Establish governance and reporting structure

Phase 2: Policy and Procedure Development (Months 2-4)

☐ System Security Plan (SSP)

- [ ] Complete SSP template documenting security environment
- [ ] Define system boundaries and authorization boundaries
- [ ] Document network architecture and data flows
- [ ] Describe security control implementation
- [ ] Map controls to responsible parties
- [ ] Include diagrams and supporting documentation

☐ Core Security Policies

- [ ] Information Security Policy (overarching framework)
- [ ] Access Control Policy
- [ ] Incident Response Policy

- [ ] Configuration Management Policy
- [ ] Media Protection Policy
- [ ] Physical Security Policy
- [ ] Personnel Security Policy
- [ ] Risk Management Policy

☐ Security Procedures

- [ ] User account management procedures
- [ ] Password management procedures
- [ ] Incident detection and response procedures
- [ ] Vulnerability management procedures
- [ ] Patch management procedures
- [ ] Backup and recovery procedures
- [ ] Media sanitization procedures
- [ ] Security awareness training procedures

☐ Plan of Action and Milestones (POA&M)

- [ ] Document all identified security gaps
- [ ] Assign risk ratings to each gap
- [ ] Develop remediation plans
- [ ] Establish completion timelines
- [ ] Assign responsible parties
- [ ] Track progress and status updates

Phase 3: Technical Implementation (Months 3-8)

☐ Access Control (AC) - 22 Controls

- [ ] Implement least privilege access principles

- [ ] Deploy multi-factor authentication (MFA) for all CUI access
- [ ] Configure role-based access control (RBAC)
- [ ] Establish account management procedures
- [ ] Implement session lock after 15 minutes inactivity
- [ ] Configure unsuccessful login attempt limits (3 attempts)
- [ ] Implement privileged account management
- [ ] Control remote access to CUI systems
- [ ] Encrypt CUI on mobile devices
- [ ] Implement wireless access restrictions

Critical Requirements:

- MFA for all users accessing CUI
- Separate user and privileged accounts
- Automated account disable after 35 days inactivity
- Remote access through managed access control points

☐ Audit and Accountability (AU) - 9 Controls

- [ ] Enable comprehensive audit logging
- [ ] Implement centralized log management
- [ ] Configure log retention (minimum 90 days for CUI systems)
- [ ] Establish audit review procedures (weekly minimum)
- [ ] Protect audit logs from unauthorized access
- [ ] Implement time synchronization across all systems
- [ ] Configure alerts for security-relevant events
- [ ] Establish audit reduction and reporting capabilities

Log Requirements:

- Successful and unsuccessful account logon events
- Account management events
- Object access (CUI files)

- Policy changes
- Privilege functions
- System events

☐ Configuration Management (CM) - 9 Controls

- ☐ Establish baseline configurations for all system components
- ☐ Implement configuration change control process
- ☐ Deploy automated configuration monitoring tools
- ☐ Restrict user-installed software
- ☐ Implement least functionality principle
- ☐ Control and monitor user-installed software
- ☐ Document security impact analysis for changes
- ☐ Maintain configuration management database

☐ Identification and Authentication (IA) - 11 Controls

- ☐ Implement unique user identification
- ☐ Deploy MFA for network and remote access
- ☐ Establish password complexity (minimum 14 characters)
- ☐ Configure password expiration (maximum 60 days)
- ☐ Implement password history (minimum 24 passwords)
- ☐ Disable accounts after 35 days of inactivity
- ☐ Implement account lockout after 3 failed attempts
- ☐ Manage authenticators (tokens, certificates)

☐ Incident Response (IR) - 6 Controls

- ☐ Develop comprehensive incident response plan
- ☐ Establish incident response team with defined roles
- ☐ Implement incident tracking and documentation system
- ☐ Define incident categories and severity levels

- [ ] Establish reporting procedures (DoD within 72 hours)
- [ ] Conduct incident response testing and exercises
- [ ] Establish forensic analysis capabilities

DoD Reporting Requirements:

- Report cyber incidents to DoD within 72 hours
- Preserve and protect incident-related information
- Provide incident details through DoD Cyber Crime Center

☐ Maintenance (MA) - 6 Controls

- [ ] Establish system maintenance policy
- [ ] Control maintenance tools and media
- [ ] Require multi-factor authentication for maintenance
- [ ] Supervise maintenance activities by non-organizational personnel
- [ ] Sanitize equipment before maintenance
- [ ] Establish remote maintenance procedures

☐ Media Protection (MP) - 9 Controls

- [ ] Mark CUI media with appropriate labels
- [ ] Control access to CUI media
- [ ] Sanitize or destroy media before disposal (NIST SP 800-88)
- [ ] Protect media during transport
- [ ] Control media storage
- [ ] Implement media accountability procedures
- [ ] Establish media sanitization procedures

Sanitization Requirements:

- Clear: Overwrite data (for reuse within organization)
- Purge: Degauss or cryptographic erase (for release outside organization)
- Destroy: Shred, disintegrate, or incinerate (for disposal)

☐ Personnel Security (PS) - 2 Controls

- ☐ Screen individuals before granting CUI access
- ☐ Ensure personnel security requirements are met
- ☐ Conduct background investigations appropriate to access level
- ☐ Establish personnel termination procedures
- ☐ Implement personnel transfer procedures

☐ Physical Protection (PE) - 8 Controls

- ☐ Limit physical access to CUI systems and facilities
- ☐ Escort visitors and monitor visitor activity
- ☐ Maintain audit logs for physical access
- ☐ Control physical access devices (badges, keys)
- ☐ Protect power equipment and cabling
- ☐ Implement emergency shutoff procedures
- ☐ Control emergency lighting
- ☐ Implement fire protection systems

☐ Risk Assessment (RA) - 3 Controls

- ☐ Conduct periodic risk assessments (annually minimum)
- ☐ Scan for vulnerabilities (monthly minimum)
- ☐ Remediate vulnerabilities based on risk priority
- ☐ Document risk assessment methodology
- ☐ Maintain risk register
- ☐ Update risk assessments when significant changes occur

Vulnerability Remediation Timelines:

- Critical: 15 days
- High: 30 days
- Moderate: 90 days

- Low: 180 days

☐ Security Assessment (CA) - 7 Controls

- ☐ Develop and implement security assessment plan
- ☐ Conduct periodic security assessments (annually)
- ☐ Develop and implement POA&M
- ☐ Establish continuous monitoring program
- ☐ Conduct penetration testing (annually for external, biennially for internal)
- ☐ Review and update security controls
- ☐ Establish security authorization process

☐ System and Communications Protection (SC) - 12 Controls

- ☐ Implement boundary protection (firewalls, IDS/IPS)
- ☐ Encrypt CUI at rest (AES-256 or equivalent)
- ☐ Encrypt CUI in transit (TLS 1.2+ or IPsec)
- ☐ Implement network segmentation
- ☐ Deny network traffic by default (whitelist approach)
- ☐ Deploy denial of service protection
- ☐ Implement split tunneling restrictions for VPN
- ☐ Establish secure name/address resolution
- ☐ Implement cryptographic key management

☐ System and Information Integrity (SI) - 5 Controls

- ☐ Deploy malware protection on all endpoints
- ☐ Update malware signatures (daily minimum)
- ☐ Implement intrusion detection and prevention
- ☐ Monitor security alerts and advisories
- ☐ Establish patch management process
- ☐ Implement security alerts for unauthorized software

- [ ] Deploy file integrity monitoring for critical files

Phase 4: Assessment Preparation (Months 7-9)

☐ Internal Readiness Assessment

- [ ] Conduct comprehensive self-assessment
- [ ] Test all security controls
- [ ] Validate evidence collection
- [ ] Review all documentation for completeness
- [ ] Address identified gaps before formal assessment
- [ ] Conduct mock assessment with Registered Practitioner

☐ Evidence Collection

- [ ] Compile screenshots of security configurations
- [ ] Collect log samples demonstrating control effectiveness
- [ ] Document policies and procedures
- [ ] Gather system diagrams and architecture documentation
- [ ] Compile training records and certificates
- [ ] Collect vulnerability scan reports
- [ ] Document incident response exercises

☐ Select Certified Third-Party Assessment Organization (C3PAO)

- [ ] Research C3PAOs from CMMC-AB marketplace
- [ ] Request proposals from multiple C3PAOs
- [ ] Verify C3PAO accreditation status
- [ ] Negotiate statement of work and pricing
- [ ] Schedule assessment timeline
- [ ] Establish points of contact

☐ Pre-Assessment Activities

- [ ] Provide C3PAO access to documentation
- [ ] Schedule assessment activities
- [ ] Coordinate site visits and remote sessions
- [ ] Brief employees on assessment process
- [ ] Prepare assessment environment
- [ ] Establish communication protocols

Phase 5: Formal Assessment (Months 9-10)

☐ Assessment Execution

- [ ] Participate in assessment kickoff meeting
- [ ] Support document review activities
- [ ] Facilitate interviews with key personnel
- [ ] Provide system access for technical testing
- [ ] Demonstrate control implementation
- [ ] Respond to assessor questions and requests
- [ ] Review preliminary findings

☐ Assessment Activities

- [ ] Document review and validation
- [ ] Personnel interviews
- [ ] Technical security testing
- [ ] Configuration review
- [ ] Vulnerability assessment validation
- [ ] Physical security inspection
- [ ] Evidence validation

☐ Findings Review

- [ ] Review draft assessment findings
- [ ] Provide additional evidence if needed
- [ ] Challenge findings if appropriate
- [ ] Understand risk ratings and impact
- [ ] Develop remediation plan for deficiencies
- [ ] Update POA&M with new findings

☐ Certification Decision

- [ ] Receive final assessment report
- [ ] Review certification recommendation
- [ ] Address any conditions for certification
- [ ] Obtain CMMC certificate
- [ ] Register certification in CMMC marketplace
- [ ] Notify customers and prime contractors

Phase 6: Continuous Compliance (Ongoing)

☐ Daily Operations

- [ ] Monitor security alerts and incidents
- [ ] Review access logs for anomalies
- [ ] Update malware signatures
- [ ] Monitor system performance and availability
- [ ] Respond to security events

☐ Weekly Activities

- [ ] Review audit logs

- [ ] Assess security alerts and advisories
- [ ] Update POA&M status
- [ ] Conduct security awareness communications
- [ ] Review access control lists

☐ Monthly Activities

- [ ] Conduct vulnerability scanning
- [ ] Review and analyze scan results
- [ ] Update risk assessment if needed
- [ ] Review user access rights
- [ ] Conduct security training sessions
- [ ] Update system inventory
- [ ] Review POA&M progress

☐ Quarterly Activities

- [ ] Review and update security policies
- [ ] Conduct security control spot checks
- [ ] Assess POA&M remediation progress
- [ ] Review incident response metrics
- [ ] Update security awareness training
- [ ] Conduct tabletop exercises

☐ Annual Activities

- [ ] Conduct comprehensive risk assessment
- [ ] Perform internal security assessment
- [ ] Update System Security Plan
- [ ] Conduct penetration testing
- [ ] Review and update all policies and procedures
- [ ] Conduct incident response exercise

- [ ] Prepare for recertification (Level 2: every 3 years)

☐ Change Management

- [ ] Assess security impact of system changes
- [ ] Update SSP for significant changes
- [ ] Conduct security testing after changes
- [ ] Update documentation and diagrams
- [ ] Notify C3PAO of significant changes if within certification period

---

Common CMMC Implementation Challenges

Challenge 1: Scope Creep

Problem: Difficulty defining clear boundaries for CUI environment
Solution: Implement network segmentation, create dedicated CUI enclaves, document clear data flows, use data classification tools

Challenge 2: Legacy Systems

Problem: Older systems that cannot meet modern security requirements
Solution: Upgrade or replace systems, implement compensating controls, isolate legacy systems, develop migration plan

Challenge 3: Cost Management

Problem: Unexpected costs for tools, assessments, and remediation
Solution: Conduct thorough gap assessment early, prioritize investments, leverage managed security services, consider cloud solutions

Challenge 4: Resource Constraints

Problem: Limited IT security staff and expertise
Solution: Engage Registered Provider Organization (RPO), use managed security services, provide staff training, hire specialized consultants

Challenge 5: Supply Chain Compliance

Problem: Ensuring subcontractors meet CMMC requirements
Solution: Establish supplier security requirements, verify subcontractor certifications, include CMMC clauses in contracts, conduct supplier assessments

Challenge 6: Documentation Burden

Problem: Extensive documentation requirements
Solution: Start early, use templates, assign dedicated resources, leverage automation tools, engage technical writers

Challenge 7: Cultural Resistance

Problem: Employee pushback on new security requirements
Solution: Communicate business value, provide comprehensive training, involve employees in planning, recognize compliance champions

---

CMMC Assessment Costs

Understanding the financial investment required for CMMC certification:

Level 1 Assessment

- **Self-Assessment:** $10,000-$25,000 (internal labor and tools)
- **Annual Requirement:** Self-assessment each year
- **Total First Year:** $35,000-$100,000 (including implementation)

Level 2 Assessment

- **C3PAO Assessment:** $30,000-$100,000 (varies by organization size and complexity)
- **Preparation Costs:** $100,000-$400,000 (gap remediation, tools, consulting)
- **Triennial Requirement:** Reassessment every 3 years
- **Total First Year:** $150,000-$500,000

- **Annual Maintenance:** $50,000-150,000$

Level 3 Assessment

- **Government Assessment:** $100,000-300,000$
- **Preparation Costs:** $400,000-1,500,000$
- **Ongoing Compliance:** $200,000-500,000$ annually
- **Total First Year:** $500,000-2,000,000+$

Cost Factors:

- Organization size and complexity
- Number of systems in scope
- Current security posture
- Geographic distribution
- Use of cloud vs. on-premises infrastructure
- Internal vs. external resources

Return on Investment

While CMMC compliance requires significant investment, the returns are substantial:

Market Access

- Access to $600+ billion annual DoD contract opportunities
- Competitive advantage in proposal evaluations
- Required for prime contractor and subcontractor roles
- Enables participation in critical defense programs

Risk Reduction

- Protection against cyber threats and data breaches
- Reduced likelihood of costly security incidents

- Enhanced intellectual property protection
- Improved business resilience

Operational Efficiency

- Streamlined security processes
- Automated compliance monitoring
- Reduced manual security tasks
- Improved incident response capabilities

Business Growth

- Expanded customer base
- Increased contract values
- Enhanced reputation and trust
- Foundation for additional certifications (FedRAMP, ISO 27001)

Average ROI Timeline:

- Break-even: 18-24 months for most Level 2 organizations
- 3-Year ROI: 200-400% through new contract wins
- 5-Year ROI: 500-800% including operational efficiencies

Essential Resources

Official CMMC Resources

- CMMC-AB.org - Cyber Accreditation Body
- CMMC Marketplace - Find C3PAOs and RPOs
- DoD CMMC Website - Official program information
- CMMC Assessment Guides - Assessment procedures

NIST Publications

- NIST SP 800-171 Rev 2 - Protecting CUI
- NIST SP 800-171A - Assessment procedures
- NIST SP 800-172 - Enhanced security for CUI
- NIST SP 800-88 - Media sanitization guidelines

DoD Resources

- DFARS 252.204-7012 - CUI contract clause
- DFARS 252.204-7019 - CMMC requirement clause
- DoD CUI Registry - CUI categories and markings
- DIB CS Program - Threat information sharing

How NexDyne Can Help

NexDyne Technology provides end-to-end CMMC implementation and certification support for defense contractors:

CMMC Gap Assessment

Comprehensive evaluation of your current security posture against CMMC requirements with detailed remediation roadmap and cost estimates.

Implementation Services

- Technical security control implementation
- Policy and procedure development
- System Security Plan creation
- Network segmentation and architecture design
- Security tool deployment and configuration

Assessment Preparation

- Internal readiness assessments
- Evidence collection and documentation
- Mock assessments and remediation
- C3PAO coordination and management

Managed Compliance Services

- Continuous monitoring and compliance management
- Monthly vulnerability scanning and remediation
- Quarterly security assessments
- Annual recertification support
- POA&M management and tracking

Training and Awareness

- CMMC awareness training for all personnel
- Role-based security training
- Incident response training and exercises
- Executive briefings and board presentations

Our CMMC Track Record:

- 40+ successful CMMC certifications (Levels 1-3)
- 98% first-time certification success rate
- Average time to certification: 7 months (Level 2)
- Zero failed assessments
- 100% client retention rate

Client Success Story: *"NexDyne guided us through CMMC Level 2 certification in just 8 months. Their expertise saved us over* $200,000 in assessment costs and helped us win a$ *15M DoD contract. The ROI was immediate."*
— CTO, Mid-Atlantic Defense Contractor

Next Steps

Ready to begin your CMMC journey? NexDyne Technology offers a complimentary CMMC readiness assessment to help you understand your current posture and path to certification.

Schedule Your Free Assessment:
Visit: www.nexdyne.com/contact
Email: cmmc@nexdyne.com
Phone: (202) 555-0100

Download Additional Resources:

- FedRAMP Readiness Checklist
- Cloud Migration Playbook for Federal Agencies
- NIST 800-171 Quick Reference Guide
- CUI Handling Best Practices

Attend Our CMMC Workshop:
Join our monthly "CMMC Essentials for Defense Contractors" workshop to learn implementation strategies and best practices from our certified experts.

This guide reflects CMMC 2.0 requirements as of 2024. Requirements may evolve as the program matures. Always consult official CMMC-AB and DoD guidance for the most current information.

© 2024 NexDyne Technology. All rights reserved.